

```
[Dheekksha@dheekksha wfuzz-master]$ wfuzz -c -z file,wordlist/others/common_pass
.txt --hc 404 -u http://testphp.vulnweb.com/FUZZ
libraries.FileLoader: CRITICAL __load_py_from_file. Filename: /usr/local/lib/pyt
hon3.7/site-packages/wfuzz/plugins/payloads/shodan.py Exception, msg=No module
named 'shodan'
libraries.FileLoader: CRITICAL __load_py_from_file. Filename: /usr/local/lib/pyt
hon3.7/site-packages/wfuzz/plugins/payloads/bing.py Exception, msg=No module nam
ed 'shodan'
*****
* Wfuzz 2.4.5 - The Web Fuzzer
*****

Target: http://testphp.vulnweb.com/FUZZ
Total requests: 52

=====
ID          Response  Lines  Word  Chars  Payload
=====
000000007:  301           7 L    12 W   184 Ch  "admin"
000000001:  200          109 L   388 W  4958 Ch  ""

Total time: 2.736923
Processed Requests: 52
Filtered Requests: 50
Requests/sec.: 18.99943
```

Figure 4: Directories fuzzed using *common_pass* with colour

```
ubuntu@ip-172-31-88-44:~$ wfuzz --script=robots -z list,robots.txt http://www.we
bscantest.com/FUZZ
*****
* Wfuzz 2.2.9 - The Web Fuzzer
*****

Target: http://www.webscantest.com/FUZZ
Total requests: 1

=====
ID          Response  Lines  Word  Chars  Payload
=====
000001:  C=200         6 L    10 W   101 Ch  "robots.txt"
|_ Plugin robots enqueued 4 more requests (rlevel=1)
000005:  C=200        85 L   197 W  3486 Ch  "/static/"
000003:  C=200        55 L   132 W  1849 Ch  "/cal_endar/"
000004:  C=200        40 L   123 W  1611 Ch  "/crawlsnags/"
000002:  C=200        40 L   117 W  1528 Ch  "/osrun/"

Total time: 0.273618
Processed Requests: 5 (1 + 4)
Filtered Requests: 0
Requests/sec.: 18.27358
```

Figure 5: Using scripts

beginning of the response and the end are shown in Figures 1 and 2. After this, additional details like the total time, number of processed requests and requests/second are also shown.

Fuzzed directories for vulnweb.com

The command used is:

```
wfuzz -w wordlist/general/common.txt -
hc 404 http://testphp.vulnweb.com/FUZZ
```

The tool's name, followed by specifying the wordlist, is followed by `--hc`.

`--hc` is used to hide the 404 responses so that not all the failed/false positives on paths and files are shown, such that only existing directories (hidden and open) are displayed. The outputs are admin, images, etc. A few of them can be added to the URL and opened but some (hidden directories) consisting only of encrypted folders/content cannot be opened. As shown, 944 requests have been filtered out of 949.

```
wfuzz -c -z file,wordlist/general/
common_pass.txt --hc 404 -u http://
testphp.vulnweb.com/FUZZ
```

This above command is a variation only to find files and it demonstrates different word files.

Here, *wfuzz* is followed by `-c` to give an output with colours for readability. *Wfuzz* has many options to decorate the output. This is followed by `-z` to specify the payloads for each *fuzz* keyword. Then comes the file, followed by the path to *common_pass.txt*, which is a file consisting of common passwords. This is the dictionary used for the brute force attack in this case.

`--hc` is added to eliminate the 404 requests. `-u` is added to specify the URL for the requests, followed by the URL and the *fuzz* keyword. The output produced shows *admin* and `""` to be the only files retrieved after brute forcing, as this word list does not contain as many words as the *common.txt* file.

Using scripts

Wfuzz's Web application vulnerability scanner is supported by plugins. A script can be active or passive, or both. Scanning mode is indicated by the `--script` parameter followed by the selected plugins.

Plugins may be selected by category or by name; wildcards can also be used. Default is usually used; in this case, robots are used to parse *robots.txt*. *Webscantest.com* is the target here.

The command is:

```
wfuzz --script=robots -z list,robots.
txt http://www.webscantest.com/FUZZ
```

Fuzzing post requests

To brute force user names and passwords, *fuzz* can be used to reveal all payloads in both unknowns.

```
<wfuzz file>wordlist/others/common_pass.
txt -d "uname=FUZZ&pass=FUZZ" --hc 302
http://testphp.vulnweb.com/userinfo.php
```

The command starts with the keyword and dictionary file. This is followed by `-d`, which specifies that